JOHNS HOPKINS

Institutional Computing Standards

Standards and Guidance for Data Center and Computing Facility Security

Approved, March 2018
Revisions Approved April 2019

Table of Contents

Table of Contents **2**

1. Summary **3**

2. Introduction **3**
- A. Background 3
- B. Audience 4
- C. Scope 4
- D. Applicable Policies 4
- E. Enforcement 5

3. Definitions and assumptions **5**

4. Server locations **7**
- A. Locked office or laboratory 7
  - (1) Standards for offices or laboratories 7

5. Server Closets **8**
- A. Controls 8
- B. Types of systems 9

6. Data Centers **9**
- A. General Controls 9
- B. Types of Systems 11

7. Encryption **11**

8. References **12**
- a. Books 12
- b. Web Sites 12

9. Appendices **12**

1. Summary

Physical security of servers and other computer assets is one of the most important elements of a sound security strategy. Johns Hopkins has many critical and Restricted servers and nearly as many physical locations for those machines. In this standard, we consider how server security should be calibrated to risk.

2. Introduction

A. Background

As a university and a health system, Johns Hopkins maintains a relatively open and visitor-friendly environment. In such an environment, physical theft is a continuing risk. The risk of theft (or loss) of Johns Hopkins IT Resources is substantial. In many settings, IT Resources are among the most valuable objects available for potential thieves. Unlike medical equipment or file cabinets for example, most computers can be carried out by one or two people easily, and there is a ready second-hand market for stolen goods. Security risk is often characterized as motive (i.e. market for stolen computer equipment) meets opportunity (i.e. an open environment). Thus, it should not be surprising that physical theft is a significant risk here.

Data centers are not built specifically for protecting against physical theft. We need data centers because the power, environmental and recoverability requirements for production enterprise computer equipment exceeds that normally available. Recent increases in processing power and storage capacity of servers and rack-based server farms have driven them into data centers. We are seeing more and larger data centers across the industry.

Data centers are restricted environments, principally because heavy traffic creates environmental and security concerns. Cameras and locks notwithstanding, security in data centers has been directed at maintaining performance, not preventing thefts. And while theft from data centers are rare, there are significant risks to systems and data. Servers in a data center often store large amounts of Restricted information and the theft of even one would represent a serious security event.

We are therefore setting forth standards for data center security that address the following:

- The differences between a data center and a server closet
- The types of equipment or data stored or processed that would necessitate data center type protections
- A list of data center type protections including access control and physical/electronic controls consistent with these standards and other security best practices.

B. Audience

The target audience for this document is anyone who is responsible for managing or administering server hosts, applications, networks or systems that are mission critical and/or handling Restricted information.

C. Scope

This document serves as both a set of standards and guidance for designing or maintaining data center and server closet security. It should also be helpful for establishing data center access policies and procedures. This document relates principally to physical security of assets and is not meant to be either an electronic security or disaster management standard.

Each department is responsible to develop its own policies or procedures regarding design, access and the like to meet its specific requirements.

D. Applicable Policies

Johns Hopkins IT Policies state the following:

Data Center Security

JH IT Resources must be physically protected commensurate with the level of risk. Systems administrators and managers must ensure that controls are planned and implemented for safeguarding physical components against compromise and environmental hazards.

Locks, cameras, alarms and other safeguards as appropriate must be installed in data centers and technology closets to discourage and respond to unauthorized access to electronic or physical components contained in these areas. See the Data Center and Computing Facilities Standards:

- *Data centers that store, process and/or transmit Restricted information must have physical access controls commensurate with the level of risk and must include the following: (1) card-swipe entry, (2) access logs, (3) access alarms (e.g. to check for propped doors), and (4) guards or video surveillance at all points of entry.*
- *Facilities with network equipment or a small number of Restricted servers or devices must have physical access controls commensurate with the level of risk and must include all of the following: (1) card-swipe entry devices with access logs, (2) access alarms (e.g. to check for propped doors). It is recommended that guards, video surveillance and hardware monitoring tool be used also.*

To protect against environmental hazards to any system, power, temperature, water and fire monitoring devices are to be deployed as appropriate.

E. Enforcement

Failure to follow these standards may be considered a violation of *Johns Hopkins Information Technology Policies,* which are incorporated by reference.

3. Definitions and assumptions

Below are some kinds of facilities in which servers generally reside. These categories overlap some and controls should be geared toward appropriate levels.

- *File servers* – in Johns Hopkins Medicine and for University administrative departments, nearly any file server with more than approximately ten users would be a Restricted system. The likelihood that PII/PHI is stored on such a server is too high to treat it

otherwise. In other parts of the institution, it is a good idea to treat file servers as Restricted, even if there is no PIIPHI is on the file server.

- *Email servers* – every email server at Johns Hopkins should be treated as Restricted. The same reasoning regarding file servers applies, and we are also concerned with email traffic (even third party) stored on the email server.
- *Application servers* – if a server processes or transmits Restricted information as part of its standard or foreseeable business purpose, it would count as a Restricted system. Any mission criticality of an application, web server, or file server raises the criticality level.
- *Web servers* – a Web server that is used to publish static pages and not support an application interface is not generally Restricted. The level of security appropriate to the server increases with risk of downtime and Restricted data loss.
- *Database servers* – mission criticality and the storage of Restricted information are the key elements. But because storage in a database is persistent, Restricted information is similar in risk to a file server, but perhaps more so because the data is served up in discrete, thief-friendly tables.
- *Management servers* –these are loosely defined as application servers used to configure or manage other machines or otherwise process on behalf of another application. Such servers often support Restricted or otherwise mission critical systems and therefore should be considered Restricted.
- *Network or other ancillary equipment* – if it stores network packets for more than seconds, such equipment should be treated as Restricted. If not, mission criticality is the test for how much physical security should be given these. In the vast majority of cases, network equipment is mission critical and requires protection commensurable to a server closet described below. We recommend that network equipment and servers not be co-located.
- *Workstation with Restricted files* – workstations storing Restricted files should be protected according to JH policy and individual circumstances. That does not usually mean that such workstations would be re-located to a data center or server closet. Please note that current policy discourages storing Restricted files onto workstations and suggests that for those who insist upon storing locally, encryption be used.

4. Server locations

A. Locked office or laboratory

The security of locked offices or laboratories varies substantially by location, size, and number of people with access and even secondary concerns like maintenance and housekeeping.

(1) Standards for offices or laboratories

1. No server or system with an institutional mission-critical purpose should be located in an office or laboratory. Departments should designate mission-criticality to servers or systems as deemed appropriate. In most cases, offices and laboratories do not have sufficient environmental controls or physical security to meet uptime requirements.
2. Restricted information may not be stored on a server in an office or laboratory. It must be stored in
3. Back-up media to servers in offices or laboratories must be encrypted and copies stored off-site for purposes of disaster recovery.
4. Storage arrays that do not use physical backups should ensure that an archival “oof-line” copy is maintained to prevent data corruption or ransomware attacks against networked storage.
5. Physical security of offices and laboratories with servers and/or several computing devices should be reviewed with campus/corporate security at least bi-annually.
6. Provisioning and tracking of keys should be handled by appropriate administrative staff. Re-keying locks periodically or based on incidents is a reasonable security response.
7. IT or administrative staff should be aware of the extent of video surveillance in or near shared offices or laboratories.
8. Restricted servers on the JH Network should be registered with deployed vulnerability scanning, host firewall and IDS as recommended by JH standards and best practices.

5. Server Closets

Server closets represent an intermediate security environment between locked offices and data centers. It is appropriate for departments to use these relatively cost-effective facilities for many of their hosts and systems. *We recommend that departmental or lab servers not be co-located with JH enterprise network equipment nor otherwise located in JH "network closets." This arrangement often results in two classes of administrators in unrelated departments and presents problems for managing physical access control.*

A. Controls

1. Environmental controls, including temperature gauges, redundant HVAC, away from water mains, etc.
2. Locked racks or cabinets for Restricted systems.
3. Encryption of Restricted data-at-rest for servers outside a data center.
4. UPS systems to cover all mission critical machines.
5. Card swipes-in to the door.
6. Door sensors to detect and trigger alarm for doors ajar.
7. Video surveillance managed by corporate/campus security at all nearby exit points.
8. Marking of equipment.
9. Managed and monitored access control list by department or IT organization.
10. The responsible IT organization and individual (with contact information) for the security of the facility should be prominently displayed.
11. Closet should not be used as an office or computer laboratory.
12. Access should be restricted to installation, repair, maintenance and trouble-shooting.
13. Risk to Restricted information should be addressed by identifying databases and other potential locations of Restricted hosts.
14. Up-time monitoring for hardware loss should be used on all Restricted hosts and a log maintained. Preferably alarm triggers will be used.

15. Policies and procedures regarding organization and storage of media (e.g. labeling, placing in locked cabinets) should be established and posted as needed.
16. An individual(s) should be made responsible to ensure that loose or unclearly affiliated equipment or media is secured in "lost and found" and not left to clutter the environment.
17. Information describing server closet infrastructure (e.g. Network topology diagrams, power feed routes, networking paths, etc.) should not be made available for general consumption.

B. Types of systems

1. Office servers (e.g. file, Web, etc.)
2. Network equipment
3. Media storage (so long as media are encrypted and marked)
4. Research databases

6. Data Centers

Data center security is the responsibility of all departments sharing data center space. The data center is a restricted area requiring a much greater level of control than normal non-public JH locations. Only those individuals who are expressly authorized may enter. Access privileges are only to be granted to individuals who have a legitimate business need to be in the data center. Furthermore, this area may only be entered to conduct authorized JH business. Those entering the data center should be familiar with data center policies.

A. General Controls

1. Each data center should have a set of policies and procedures that includes the controls below, incident response, and relationship with corporate/campus security, etc. The

policies should be reviewed and revised bi-annually or more frequently if required by specific regulatory regimes.

2. Review process for new and existing equipment, including checklists regarding hardware and network requirements, registration through systems inventories, back-up processes and "who, what and how often" of maintenance. Servers must be registered with and tracked by the central Configuration Management Database (CMDB).
3. For environmental and system configuration changes, a formal change management process should be instituted.
4. Environmental controls, including temperature gauges, fire suppression, emergency, shut-off, independent and redundant HVAC, no water mains nearby.
5. Raised floors or other means of ensuring air circulation
6. UPS supplied to racks.
7. In data centers where there are multiple administrator groups – thus a risk of roving access – racks should be organized and locked so as to minimize risk of unauthorized access
8. Card-swipes in for each door
9. Door sensors to detect and trigger alarm for any doors kept open.
10. Where possible card access should be layered (e.g. a mantrap or supplementary pin codes after card swipe entry)
11. Video surveillance at each point of entry, at all nearby building exits and strategically placed cameras inside the data center.
12. Sign-in (preferably within view of a camera) with additional form for transfer (in or out) of equipment. Complete logs should be maintained regarding transfer of hardware and media.
13. Clear marking of rows and equipment.
14. Managed and audited access control list, matching need for access to sign-ins and electronic sign-ins.
15. "Break glass" emergency access coordinated with corporate/campus security and capable of being used for time-critical maintenance.
16. The organization (with contact information) responsible for data center security and access and use policies should be prominently displayed.

17. Escorts and cards are required for vendors or other third parties. Escorts should be associated with the management team of the data center and not simply anyone with access to the data center. Both escort and visitor must card-swipe in, sign-in and sign-out. Visitor access must be logged.
18. Up-time monitoring for hardware loss should be used on all Restricted hosts and a log maintained. Preferably alarm triggers will be used.
19. Policies regarding media handling (e.g. labeling, placing in locked cabinets) should be established and posted where there is a media library in the data center.
20. An individual(s) should be made responsible to ensure that loose or unclearly affiliated equipment or media is secured in a clearly designated area.
21. Avoid using water as primary agent for fire suppression.
22. Work with building facilities management team to establish minimal acceptable conditions for operating the data center. Periodically review with facilities team.
23. Information describing data center infrastructure (e.g. Network topology diagrams, power feed routes, networking paths, etc.) should not be made available for general consumption.
24. A complete risk assessment should be undertaken bi-annually.

B. Types of Systems

1. Mission critical applications
2. Enterprise Restricted applications (including email, Web, etc.,)
3. Storage arrays
4. Enterprise monitoring tools
5. Departmental and enterprise databases
6. Back-up media encryption

7. Encryption

One of the principal reasons to encrypt is to ensure that back-up media are properly encrypted and follow encryption requirements and Guidance in our *Johns Hopkins Encryption Standards and Guidance*. Key management can be scaled by combining multiple systems into a small number of encryption processes and tools. Each data center should have a plan for working with customers on encryption.

8. References

a. Books

None

b. Web Sites

- http://www.cisco.com/web/about/ciscoitatwork/white_papers/datacenter_dl3.html
- http://www.informit.com/articles/article.aspx?p=174098&rl=1

9. Appendices

None